

Attacking Active Directory: Tools and Techniques for Using your AD Against You

By **Darren Mar-Elia** December 14, 2017 | [Disaster Recovery](#)

The Problem with Active Directory

Since it was introduced in 2000, Active Directory has become the most critical application for the majority of enterprises. The problem is, that in the almost two decades since it was released, the enterprise security landscape has changed drastically and businesses have not adapted their Active Directory environment to meet these new security needs. Delegations have been handled haphazardly and default permissions on objects are optimized for discovery, not security. In sufficiently large environments, you don't know what you don't know, making it tough to determine what you need to get control over in order to prevent hackers from attacking Active Directory. In addition, in recent years, attackers have gotten more sophisticated—it's not just about compromising single systems, it's about finding quicker paths to compromising more interesting systems.

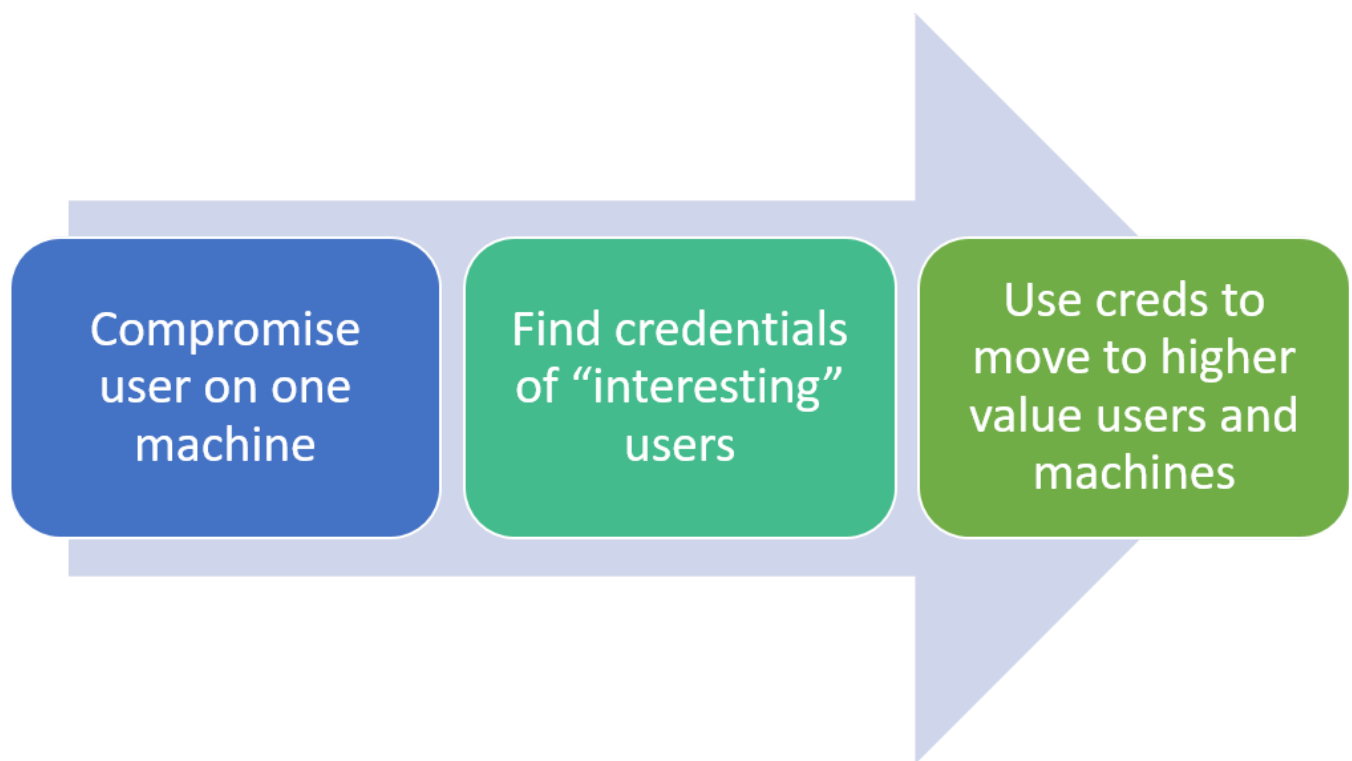
Common Points of Weakness

Managing delegations in Active Directory has been an obvious problem for quite some time. While it might have been a great idea to build Active Directory with read access for all Authenticated Users 17 years ago, unfortunately this is no longer the case. Many shops have gotten better about implementing rigid policies for Domain Admins, but it's the next tier of users that's more interesting to an attacker because those are the users that have access to sensitive information as well (i.e. most privileged group memberships are usually readable by Authenticated Users). If an attacker can gain access to a privileged account and fish around Active Directory, then they can learn useful information about what's in AD from a privileged access perspective and create a blueprint of that environment.

Another vulnerability lies in the fact that non-administrative users may be granted rights to take privileged actions. Something you might want to think about is – who are you granting Reset Passwords rights to your admin accounts? Attackers can look at Access Control Lists (ACLs), see who has access to which objects, and use that information to compromise Active Directory. If a helpdesk person can reset passwords on your most privileged users, and an attacker gains access to that person's account, then you're essentially allowing that attacker to escalate themselves to a more privileged position.

Common Methods of Attacking Active Directory

Most attackers gain access to Active Directory through stolen credentials and, unfortunately, there are a multitude of methods for hacking an [Active Directory password](#). "Pass the hash" is a Windows-specific instance of credential theft where an attacker can gain access to a server or service with a user's password hash, and not the cleartext password. This method involves stealing the LAN Manager Hash or Kerberos keys of a user from LSASS memory on a Windows System. Credential theft is a common way to facilitate moving laterally.



Other tools that attackers can use to penetrate and compromise Active Directory include:

- Described as “a little tool to play with Windows security”, [Mimikatz](#) is probably the most widely used AD exploitation tool and the most versatile. It provides a variety of methods for grabbing LM Hashes, Kerberos tickets, etc.
- [PowerSploit](#) is a PowerShell-based toolkit for recon, exfiltration, persistence, etc.
- [Bloodhound](#) is a graphical tool for finding relationships in AD environments that help speed the path to privileged access.
- [Death Star](#) shows how you can use information collected from Bloodhound and other tools to automate the elevation to Domain Admin (or similar).

Measures to Protect Active Directory

The good news is that, despite all the potential for exploitation, there is a lot you can do to make it harder for attackers to move around Active Directory.

- **Reduce information exposure** through privileged AD users and groups, GPOs, etc. Constrain where credentials are “lying around” and use built-in technologies such as Credential Guard and Remote Credential Guard in Win10 Pro & Enterprise/2016.
- **Monitor, monitor, monitor** your IT environment using an [Active Directory auditing tool](#). There’s also a great white paper that documents [lateral movement-related events](#).
- **Harden privileged groups:** member attribute should not be world-readable. Delegation of full-control or write of the group’s member attribute should be restricted to other privileged users at the same or higher privilege tier.
- **Harden privileged users:** reset password, take ownership or full control permissions should be tightly controlled to other users at the same privilege tier.
- **Harden GPOs:** GPOs that grant privileged access should not be world-readable and GPOs that contain security settings should be restricted on Reads.

- **Consider restricting credentials** using the Tiered Admin Model presented in [Microsoft's Pass-the-Hash white paper](#).

While taking these preventative measures makes it harder for attackers to compromise AD, once an attacker is hiding in your environment, there's no way of preventing them from attacking Active Directory and wiping out your environment. That's why implementing a Disaster Recovery solution is **the** single most critical step you can take to protect Active Directory. Semperis' [Active Directory State Manager](#) gives you visibility over changes happening to your AD so that you can more quickly spot suspicious activity within the Directory, and the fully-automated [Active Directory Forest Recovery](#) solution makes recovering from an AD attack as simple as three mouse clicks, reducing your time to restore from weeks to hours. With all the new techniques that exist for attacking AD, it's time to stop thinking about what you'll do if someone attacks your Active Directory environment and start preparing your AD Disaster Recovery plan.